

Título: Vulnerabilidad Crítica de inyección SQL en DVWA

Autor: Juan Brun

Institución: 4Geeks

Fecha: 31/05/2026

El presente informe detalla un incidente de seguridad identificado durante las pruebas de evaluación en el entorno de la aplicación web DVWA. El objetivo de este documento es clasificar, documentar y proponer soluciones para la vulnerabilidad encontrada, cumpliendo con los estándares de la gestión de incidentes de la norma ISO 27001.

Descripción del incidente:

Se ha detectado una vulnerabilidad de inyección SQL en el formulario de consulta de usuario de la aplicación. El campo de entrada USER ID no sanitiza ni valida correctamente los caracteres ingresados por el usuario, lo que permite a un atacante inyectar y ejecutar código SQL.

Proceso de Reproducción: Para ver el incidente y verificar la vulnerabilidad, se deben seguir una serie de pasos:

- 1) Acceder a la aplicación web DVWA a través de la dirección local (<http://localhost/DVWA>)
- 2) Iniciar sesión utilizando las credenciales ingresadas en él informe: Usuario admin; Contraseña: password
- 3) Dirigirse a la pestaña "DVWA security" y configurar el nivel de seguridad en "Low"
- 4) Navegar en la sección "SQL injection"
- 5) En el campo de User ID, se ingresa la siguiente carga útil: "1 OR '1'='1"
- 6) Hacer clic en "Submit". El resultado es que la aplicación devuelve y expone en pantalla la lista completa de usuarios registrados en la base de datos, dando datos como el First name y Surname

Impacto del Incidente: El impacto de esta vulnerabilidad es CRÍTICO. Al lograr una inyección SQL exitosa, se compromete por completo la confidencialidad de los datos, permitiendo el acceso no autorizado a información sensible de todos los usuarios. Dependiendo de los privilegios del usuario de la base de datos, este fallo podría escalar para comprometer la integridad y disponibilidad del servidor (modificar o eliminar datos)

Recomendaciones: Para mitigar esta vulnerabilidad y prevenir futuros incidentes, se recomienda implementar las siguientes medidas:

- 1) Consultas Parametrizadas: Modificar el código backend (PHP) para utilizar PDO o MySQL con sentencias preparadas. Esto asegura que la base de datos trate el input del usuario estrictamente como datos y no como código ejecutable.

2) Validación y Sanitización de Entradas: implementar validaciones estrictas en el lado del servidor para asegurar que el User ID solo acepte valores numéricos enteros esperados.

3) Principio de Menor privilegio: Asegurar que el usuario de la base de datos configurado en 'config.inc.php' tenga únicamente los permisos necesarios para operar la aplicación, evitando el uso de cuentas como root.

Conclusión: La vulnerabilidad de Inyección SQL identificada en DVWA representa un riesgo de seguridad severo que requiere atención inmediata en un entorno de producción. La implementación de las recomendaciones descritas, especialmente el uso de consultas parametrizadas, cerrara esta brecha de seguridad y alineara el desarrollo con las mejores prácticas de codificación segura.